

Final Project Part 2

The Hospital, Part 2

Congratulations! You are a finalist for the hospital's lead cybersecurity engineer! Last week, you were tasked with conducting a non-destructive penetration test. You were only permitted to exploit three machines. However, during your scans you may have found some additional vulnerable machines that may need further investigation. You mentioned this to the board and they have agreed to let you perform another penetration test on the additional machines. If you performed as well on this test as you did the last, you're sure to land the job!

Since it's the final week of your assessment test, you've been sure to get a good night's rest. You wake up feeling well-rested and begin to make yourself some scrambled eggs and cinnamon toast for breakfast. After eating, you head out to your job, but you get an email before you leave the house. It's from Tom, the cybersecurity director! As you open the email, you read the following:

I almost forgot

From: Tom

I almost forgot

Greetings!

This is Tom, the retiring cybersecurity director. I commend you on your progress in your application; I am very impressed with the work you've accomplished! In fact, I'm going to hand off a project of mine to you as a gift.

A month ago, I was in charge of patching an old machine found to have *some* security flaws, misconfigurations, etc. I didn't have the time to get around to securing it, so I just put it behind my personal network firewall. Given that I'm retiring this week, it looks like I won't be able to get around to it. Fortunately for me, you and the other applicants have proven to be really handy at finding and remediating vulnerabilities!

I've deployed copies of my old machine to you and the other applications. It should be on your network by the time you're reading this. Consider it another part of your application! If I were you, I'd get to hacking... may the best pentester win! 🏆

Love, Tom <3

Statement of Work

Summary

This Statement of Work ("SOW") is between the Client (The Hospital) and the Contractor (You), effective the week of the Final Project Week 2

As of the Effective Date, this SOW is entered into by and between the Client and Contractor and is subject to the terms and conditions specified below. In the event of inconsistency between the terms of this SOW and the Agreement, the terms of the SOW shall prevail. This SOW between the parties is entered into in connection with an existing agreement between the parties. All terms used but not defined herein shall have the meanings outlined in the Agreement.

Purpose

The purpose of this SOW is agreed to by the parties as follows:

- (1) To exploit these specific IP addresses: X.X.X.152, X.X.X.154, and X.X.X.175
- (2) To identify remediations and corrective actions for any vulnerabilities identified in Purpose (1)
- (3) To identify and locate any breaches or indicators of compromise within any of the machines X.X.X.150-X.X.X.176

Scope of Work

This SOW outlines the tasks and deliverables currently anticipated by the parties during the SOW term. Beginning the effective date, rules shall be set forth as follows:

1. The contractor may attempt to exploit vulnerabilities and gain access to any machines within the X.X.X.150-175, given that all exploits and vulnerabilities found must be thoroughly documented and reported to the client.
2. The contractor may look at any files accessed throughout the audit, given the condition that all sensitive information found is to be thoroughly documented and reported to the client.
3. The contractor may not be allowed to alter the integrity, availability, or permissions of patient and employee data throughout the audit. (i.e., no modifying or deleting healthcare documents, employment records, etc)
4. The contractor may not establish persistence.
5. The contractor will not be given usernames and passwords.
6. The contractor may not disable or block any ports or services (Excluding SMBv1)

7. The contractor will attempt to identify and report any evidence regarding indicators of compromise on the hospital's network.

Documentation for the Client:

Exploiting the machines

As stated in the SOW, you must exploit these three machines: the Reception Desktop, the Clinician Desktop, and Tom's Project. To do well on the skills test, you're expected to be able to break into each of the machines.

Machines	How did you gain access?	What specific harm could be done?	How can you remediate it?
Reception Desktop			
Clinician Desktop			
Tom's Project			

Sensitive information

As stated in the SOW, it is your responsibility to locate and document whatever sensitive data you can find on the Reception Desktop, Clinician Desktop, and Tom's Project. This could happen during or after any of the other steps.

Host Machines	What Information I found, and why it's bad that I can see it.
Reception Desktop	
Clinician Desktop	
Tom's Project	

Remediation

The lead cybersecurity engineer is responsible for overseeing offensive operations (Pentesting and Red Teaming) and managing the protection and remediation of vulnerable systems. To do well in this stage of the recruitment process, you are expected to address any misconfigurations and vulnerabilities identified. You may attempt to remediate the issue. If you choose not to remediate, you must explain how you would go about remediating the problem.

Host Machines	For each vulnerability, misconfiguration, sensitive information disclosure, and malpractice answer the following: Does the issue need to be fixed? Why, or why not?	If actions were taken, how did you remediate it? If not, how would you remediate it?
Reception Desktop		
Clinician Desktop		
Tom's Project		

Indicators of Compromise

Relating to the 7th point in the Scope of Work. You must thoroughly document the entire process while responding and remediating your security breaches. For each machine that is accessed, you should note any indications of compromise that are found on the machine, such as users that were created, files indicating intrusion, and more, and you must report it and take a screenshot.

Some potential hints of things that might be good to look for include:

- .158 (ems_laptop), do you notice any new users / files?
- .150 (www) Look for signs of users/reading data that shouldn't be publicly shared
- .175 (toms surprise)

Be specific in what you find, being vague will get you 0 points.

Host IP	1. What was accessed? 2. How was it accessed? 3. What was the impact of the incident? 4. How did you respond to the incident? 5. Screenshot of what was accessed

Notes:

Please complete the each table found in the lab description above. Each line in the table must be numbered and have a numbered corresponding screenshot to prove your claim. Your lab report is **REQUIRED** to use these tables/formats, or points will be taken away. You must copy the template provided and fill in the tables accordingly. Your lab report is **REQUIRED** to use the template below, or points will be taken away. You are expected to be very thorough in your answers. Vague descriptions or responses that don't correctly answer the questions from the table will receive zero credit. As a general rule, the more descriptive and informative your answer, the more likely you will receive credit. The less descriptive and uninformative your answer, the more likely it is that you will receive no credit. A good answer should be no less than two sentences.

Final Project Part 2 Template

(Note: the points for each row are given on an all-or-nothing basis. You must properly fill out each column in the row to receive all of the points. Correctly filling out 2/3 of the information earns zero points. Every answer must be adequate to receive full credit for the given row.)

Exploiting three machines (8.3 points per row; 25 total points)

Host Machines	How did you gain access?	What <u>specific</u> harm could be done?	How can you remediate it?
Reception Desktop			
Clinician Desktop			
Tom's Project			

Sensitive information (8.3 points per row; 25 total points)

Host Machines	What information I found, and why it's bad that I can see it.
Reception Desktop	
Clinician Desktop	
Tom's Project	

Remediation (8.3 points per row; 25 total points)

Host Machines	Vulnerabilities, misconfigurations, sensitive information disclosures, malpractices	Does the issue need to be fixed? Why, or why not?	If actions were taken, how did you remediate it
Reception Desktop			
Clinician Desktop			
Tom's Project			

Incident Response Table (8.3 points per row; 25 total points)

Some potential hints of things that might be good to look for include:

- .158 (ems_laptop), do you notice any new users/files?
- .150 (www) Look for signs of users/reading data that shouldn't be publicly shared
- .175 (toms surprise)

Be specific in what you find, being vague will get you 0 points.

Host IP	1.) What was accessed? 2.) How was it accessed? 3.) What was the impact of the incident? 4.) How did you respond to the incident? 5.) Screenshot of what was accessed